

Blue Team en la red: OPNsense

0. ¿pfSense u OPNsense? Usamos OPNsense

Para esta práctica usamos **OPNsense** en lugar de **pfSense** por 3 motivos:

Motivo	Detalle
Más moderno	Dos versiones mayores al año (enero y julio); interfaz web rediseñada.
Todo integrado	Bloqueo de dominios (Unbound Blocklists), IDS/IPS Suricata y Web Proxy vienen de serie. En pfSense necesitarías instalar pfBlockerNG / Squid aparte.
Conocimiento transferible	OPNsense es un <i>fork</i> de pfSense: conceptos (WAN/LAN, NAT, reglas stateful) son idénticos. Lo que sabéis de pfSense os vale.

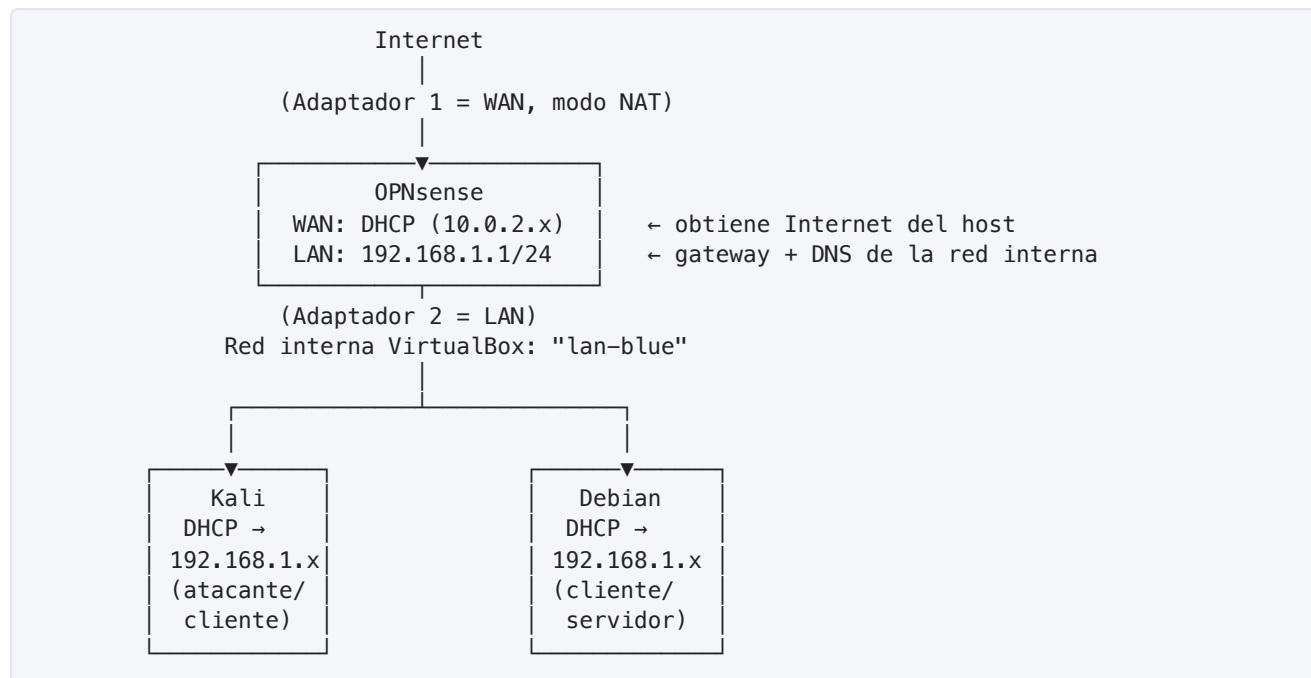
Si prefieres pfSense, la **topología y los objetivos son los mismos**; solo cambian los nombres de algunos menús (p. ej. el bloqueo por DNS sería **Firewall** > **pfBlockerNG**).

1. Objetivos de aprendizaje

Al terminar serás capaz de:

1. Construir una red de laboratorio donde un firewall hace de **única puerta de enlace** entre tus VMs e Internet.
 2. Comprobar que **el tráfico de Kali y Debian se enruta por OPNsense** (no salen por su cuenta).
 3. Escribir **reglas de firewall** con estado y entender **Pass** / **Block** / **Reject** , la dirección del tráfico y el orden de evaluación.
 4. **Bloquear sitios web** correctamente, entendiendo por qué un firewall NO es la herramienta adecuada para bloquear *dominios* y sí lo son el **DNS** y el **proxy**.
 5. Aplicar control **por host** (bloquear a Kali pero no a Debian) → base de la segmentación / DMZ.
 6. Activar un **IDS (Suricata)** y observar alertas de tráfico malicioso (NDR en la práctica).
-

2. Arquitectura del laboratorio



VM	Rol	Adaptador 1	Adaptador 2	Dirección IP
OPNsense	Router / Firewall	NAT (WAN)	Red interna lan-blue (LAN)	WAN: DHCP · LAN: 192.168.1.1/24
Kali	Cliente / atacante	Red interna lan-blue	—	DHCP (192.168.1.x)
Debian	Cliente / servidor	Red interna lan-blue	—	DHCP (192.168.1.x)

Idea clave: Kali y Debian están en una red **aislada** (**Internal Network**) que solo conoce a OPNsense. Su única salida a Internet es a través del firewall → así *garantizamos* que todo su tráfico es filtrable.

3. Requisitos previos

- Virtualizador: **VirtualBox** (gratis, multiplataforma). Más abajo hay equivalencias para VMware.
- ISO de OPNsense: descarga la **última estable** (a día de hoy, serie 25.7 / 26.1 o posterior) desde <https://opnsense.org/download>.
- **Type:** **dvd** (imagen ISO, arranque VGA) · **Architecture:** **amd64** . Descomprime el **.bz2** (con 7-Zip en Windows o **bunzip2** en Linux/macOS) hasta obtener el **.iso** .
- VMs de **Kali** y **Debian** que ya tienes del curso.
- Recursos sugeridos para OPNsense: **1-2 vCPU, 1-2 GB RAM, 8-16 GB disco**.

Verificación de integridad (buena práctica de Blue Team): OPNsense publica **.sha256** y firma **.sig** + clave pública **.pub** . Comprobar el hash antes de instalar es exactamente el tipo de control que defiende un equipo azul.

4. Fase 1 — Crear y cablear las VMs (VirtualBox)

4.1 Crear la VM de OPNsense

1. **Nueva** → Tipo **BSD**, Versión **FreeBSD (64-bit)**. Asigna RAM/disco según arriba.
2. Monta la **ISO** de OPNsense en el lector óptico de la VM.

4.2 Configurar las dos tarjetas de red de OPNsense

En **Configuración > Red** de la VM OPNsense:

- **Adaptador 1** → Habilitado → **Conectado a: NAT** (será la WAN; da Internet desde el host).
- **Adaptador 2** → Habilitado → **Conectado a: Red interna** → Nombre: **lan-blue** (será la LAN).

4.3 Conectar Kali y Debian a la LAN

En cada una de esas VMs, **Configuración > Red > Adaptador 1**:

- **Conectado a: Red interna** → Nombre: **lan-blue** (exactamente el mismo nombre).

El orden importa: el **primer** adaptador que OPNsense detecte lo asignaremos como LAN y el segundo como WAN (lo confirmamos en la consola en la Fase 2). Si te lías, no pasa nada: se reasignan desde la consola.

Equivalencia en VMware (Workstation/Fusion)

VirtualBox	VMware
Adaptador NAT (WAN)	NAT (VMnet8)
Red interna lan-blue (LAN)	LAN Segment (Workstation) / red personalizada aislada (Fusion)

En VMware, **desactiva el DHCP** de ese segmento/red para que **el único** servidor DHCP sea OPNsense. En VirtualBox la **Red interna** no tiene DHCP propio, así que no hay conflicto.

5. Fase 2 — Instalar OPNsense

1. Arranca la VM con la ISO. OPNsense entra en **modo live**.
2. En el **login:** introduce el usuario **installer** y contraseña **opnsense** (credenciales por defecto del *live*).
3. Sigue el instalador: - **Keymap:** deja el valor por defecto (o **Spanish**). - **Filesystem:** elige **ZFS** (recomendado; **stripe** sobre un solo disco) o UFS si vas muy justo de disco. - **Disk Selection:** selecciona el disco virtual (p. ej. **da0** / **nvd0**). - **Last Chance!:** **Yes** → formatea el disco. - **Root Password:** define una contraseña (en laboratorio puedes dejar **opnsense**). - **Complete Install** → reinicia. **Quita la ISO** del lector al reiniciar.

5.1 Asignación de interfaces (consola)

Tras arrancar instalado verás el **menú de consola** (estas son las 13 opciones reales):

0) Logout	7) Ping host
1) Assign interfaces	8) Shell
2) Set interface(s) IP address	9) pfTop
3) Reset the root password	10) Filter logs
4) Reset to factory defaults	11) Restart web interface
5) Reboot system	12) Upgrade from console
6) Halt system	13) Restore a configuration

- Si las interfaces no quedaron como quieres, usa **1) Assign interfaces** :
- **LAN** → la NIC de la red interna (la `em0` / `vtnet0` conectada a `lan-blue`).
- **WAN** → la NIC en modo NAT.
- (VLANs: responde **no** .)

Al terminar, OPNsense muestra algo como:

```
WAN (vtnet1) -> v4/DHCP4: 10.0.2.15/24
LAN (vtnet0) -> v4: 192.168.1.1/24
```

Por defecto: **LAN = 192.168.1.1/24 con DHCP activado, WAN = DHCP**. No toques nada más en consola; el resto se hace desde la web **desde un cliente de la LAN**.

6. Fase 3 — Acceso web y comprobación del enrutamiento

A OPNsense **se administra desde la LAN** (la WAN, por defecto, bloquea el acceso). Por eso abrimos la consola web **desde Kali o Debian**.

1. Arranca **Kali** y **Debian**. Con DHCP de OPNsense deberían recibir IP automáticamente.
2. En **Debian** (o Kali), comprueba la red:

```
ip a          # ¿Tienes una IP 192.168.1.x?
ip route      # default via 192.168.1.1 → la puerta de enlace es OPNsense
cat /etc/resolv.conf # nameserver 192.168.1.1 → el DNS también es OPNsense
ping -c3 192.168.1.1 # ¿Llegas al firewall?
ping -c3 1.1.1.1     # ¿Hay Internet por IP? (enrutamiento/NAT)
ping -c3 google.com  # ¿Hay Internet + DNS? (resolución)
```

3. Abre el navegador en la VM → **https://192.168.1.1** (acepta el certificado autofirmado). -
 Usuario **root** · contraseña **opnsense** (o la que pusiste). - Completa el **asistente inicial**
 (hostname, DNS, zona horaria). Puedes dejar casi todo por defecto.

✅ **Hito 1 — Enrutamiento conseguido:** si Kali y Debian navegan a Internet y su `ip route` apunta a **192.168.1.1** , **ya estás enrutando su tráfico por OPNsense**. Todo lo que filtremos a partir de aquí les afecta.

Nota sobre la WAN en NAT: OPNsense trae activado en la WAN "Block private networks". Como la WAN está detrás del NAT de VirtualBox (una IP privada `10.0.2.x`), **la salida a Internet funciona igualmente** (el tráfico de retorno se permite por estado). No necesitas desactivarlo para esta práctica; solo administra desde la LAN.

7. Fase 4 — Reglas de firewall (bloqueo a nivel de paquete, L3/L4)

Conceptos que confirmamos antes de tocar nada (de la lectura de Cortafuegos):

- OPNsense es un **firewall con estado (stateful)**: basta permitir el tráfico en **una** dirección; las respuestas vuelven solas.
- Acciones: **Pass** (permitir), **Block** (descartar en silencio), **Reject** (descartar avisando: RST en TCP / ICMP unreachable en UDP).
- Se filtra por **dirección de entrada**: la regla se pone en la interfaz **por donde entra** el tráfico. Para tráfico que sale de tus PCs, la regla va en **LAN**.
- **Orden**: las reglas con **quick** (por defecto) son "**primera coincidencia gana**", de arriba abajo. La regla por defecto "allow LAN to any" deja salir todo; nosotros añadiremos bloqueos **por encima**.

Menú: **Firewall > Rules > LAN** → botón **+** (añadir, arriba).

Ejercicio 4.1 — Bloquear ping (ICMP) hacia Internet

Objetivo: ver una regla en acción de forma inmediata.

Campo	Valor
Action	Block
Interface	LAN
Direction	in
Protocol	ICMP
Source	LAN net
Destination	any
Log	✓ (marcado)
Description	Lab: bloquear ICMP saliente

Guarda → **Apply changes**. Coloca esta regla **por encima** de la regla "default allow LAN".

Prueba desde Kali/Debian:

```
ping -c3 1.1.1.1      # ahora debe FALLAR (100% packet loss)
curl -I https://example.com # esto SIGUE funcionando (es TCP/443, no ICMP)
```

Mira el log en **Firewall > Log Files > Live View**: verás los paquetes ICMP bloqueados con tu descripción.

Pregunta rápida: ¿por qué la web sigue cargando si "no hay Internet"? Porque solo bloqueaste ICMP, no TCP. *El firewall filtra por protocolo/puerto, no por "Internet" en abstracto.*

Ejercicio 4.2 — Control por host (segmentación)

Objetivo: bloquear a **Kali** un servicio y dejárselo a **Debian**. Es la base de una DMZ: distintos hosts, distintas políticas.

1. Fija las IPs para identificarlas (mira **ip a** en cada VM; supongamos Kali = **192.168.1.10**).
2. Crea una regla en **LAN**:

Campo	Valor
Action	Reject
Interface	LAN
Protocol	TCP
Source	192.168.1.10 (Kali)
Destination	any
Destination port	HTTPS (443)
Description	Lab: Kali sin HTTPS

Prueba: desde **Kali** `curl -I https://example.com` → falla al instante (Reject). Desde **Debian** → sigue funcionando. Has aplicado una política **por origen**.

💡 **Pass vs Block vs Reject:** repite el 4.2 cambiando **Reject** por **Block** y observa la diferencia desde Kali: con **Reject** el `curl` falla rápido (recibe un RST); con **Block** se queda **colgado hasta el timeout** (descarte silencioso). Para redes internas se suele preferir **Reject** ; hacia Internet (WAN), **Block** .

⚠️ **Si una regla "no hace efecto":** el firewall mantiene **estados**. Tras crear/editar reglas, resetea con **Firewall > Diagnostics > States** , o cierra la conexión y reintenta.

8. Fase 5 — Bloquear sitios web (la forma correcta)

El concepto que casi todo el mundo confunde

Un firewall de paquetes filtra por **IP y puerto** (capa 3/4). **No entiende de dominios**. Para bloquear **ejemplo.com** necesitas algo que trabaje a **nivel de aplicación/DNS (capa 7)** — exactamente lo que decía la lectura de **servidores proxy**.

Tienes dos vías limpias en OPNsense:

Método A (recomendado) — Bloqueo por DNS con Unbound *Blocklists*

OPNsense resuelve el DNS de tus clientes (es su DNS), así que puede "**agujerear**" (**sinkhole**) los dominios que no quieras.

Menú: **Services > Unbound DNS > Blocklists** .

Campo	Qué hacer
Enable	✓
Wildcard Domains	Añade un dominio de prueba, p. ej. example.com (bloquea también todos sus subdominios). <i>No se puede bloquear un TLD entero como com.</i>
Blocklist Domains	Lista de dominios exactos a bloquear (sin comodín, sin regex).
Type of DNSBL	(Opcional) marca listas predefinidas: AdAway , AdGuard , OISD , EasyList , Abuse.ch ThreatFox... para bloquear publicidad/malware en masa.
Allowlist Domains	Excepciones (lista blanca).
Return NXDOMAIN	Devuelve NXDOMAIN en vez de 0.0.0.0 (útil para dispositivos quisquillosos).

Guarda → **Apply**. (El cambio tarda hasta ~1 min en cargarse; Unbound no se reinicia.)

Prueba desde Kali/Debian:

```
nslookup example.com 192.168.1.1    # → debería responder 0.0.0.0 (o NXDOMAIN)
# o con dig (instala dnsutils si no lo tienes: sudo apt install dnsutils):
dig example.com @192.168.1.1
```

Y en el navegador: **http://example.com** ya no carga.

Extras útiles (verificados):

- **Blocklist Tester** (misma pestaña): comprueba si un dominio casa con tus reglas, sin salir de OPNsense.
- **Actualización automática** de las listas: **System > Settings > Cron** → añade la tarea "**Update Unbound DNSBLs**" (una vez al día basta).
- **Force SafeSearch** (en **Services > Unbound DNS > General**): fuerza el modo seguro de Google/Bing/YouTube/DuckDuckGo, etc.

Método B (didáctico) — Alias por dominio + regla de firewall, y por qué falla

Para ver con tus propios ojos la limitación del firewall:

1. **Firewall > Aliases > +** → Tipo **Host(s)** → Nombre **web_bloqueada** → contenido: **www.youtube.com** (un FQDN; OPNsense lo resuelve a IPs cada 300 s).
2. **Firewall > Rules > LAN** → regla **Block**, Source **LAN net**, Destination = alias **web_bloqueada**.
3. Inspecciona el alias en **Firewall > Diagnostics > Aliases**: verás **varias IPs** y cambiantes.

NOTA: sitios grandes usan **CDNs** con muchas IPs rotativas y compartidas → bloquear por IP es **frágil e impreciso**. Por eso para *dominios* se usa **DNS (Método A)** o un **proxy**, no el firewall de paquetes.

✅ **Hito 2 — Filtrado web:** has bloqueado una web por DNS (fiable) y has comprobado por qué hacerlo por IP en el firewall no es buena idea. Esa es la diferencia L3/L4 vs L7 de la teoría.

9. Fase 6 — "Algo más complejo" (elige uno o varios)

9.1 Forzar el uso del DNS del firewall (anti-bypass)

Problema real: un usuario listo configura **8.8.8.8** a mano y se **salta** tu bloqueo por DNS. Solución de Blue Team: **redirigir y/o bloquear** todo el DNS saliente.

1. **Redirección (NAT):** **Firewall > NAT > Port Forward** → en **LAN**, Protocolo **TCP/UDP**, **Destination port = DNS (53)**, **Redirect target IP = 127.0.0.1**, **Redirect target port = 53**. Esto reconduce cualquier consulta DNS al propio Unbound.
2. **Bloqueo de fuga:** una regla **Block** en LAN para **Destination port 53** hacia destinos que **no** sean OPNsense.

Prueba: desde Kali **nslookup example.com 8.8.8.8** → debería seguir devolviendo tu sinkhole (no el resultado real de Google), demostrando que ya **no pueden esquivar** el filtro.

Es la misma técnica recomendada por OPNsense cuando usas DNS-over-TLS: bloquear el 53 saliente y redirigir a **127.0.0.1:53**.

9.2 NDR en la práctica — IDS con Suricata

Aterriza la lectura de **NDR**: vamos a *detectar* tráfico sospechoso analizando la red.

Menú: **Services > Intrusion Detection > Administration**.

Campo	Valor
Enabled	✓
Capture mode	PCAP live mode (IDS) → solo alerta. (<i>En versiones que muestran un interruptor "IPS mode", déjalo desactivado: equivale a lo mismo.</i>)
Promiscuous mode	✓
Interfaces	LAN (<i>¡no WAN!</i>)
Pattern matcher	Aho-Corasick (por defecto)

¿Por qué LAN y no WAN? En la WAN, por el NAT, todo el tráfico parece venir del firewall y **pierdes la IP interna real** del equipo implicado. En la LAN ves quién es quién. (Lo explica la propia doc de OPNsense.)

1. Pestaña **Download** → marca **ET Open / Emerging Threats Open** (ruleset gratuito) → **Download & Update Rules**.
2. (Opcional) **Policies** → controla qué reglas solo *alertan* y cuáles *descartan*.
3. **Genera tráfico de prueba desde Kali:** **bash curl http://testmyids.com # test** clásico de IDS (respuesta "uid=0(root)...") # o un escaneo contra Debian: **nmap -sS -p 1-1000 192.168.1.<ip_debian>**
4. Revisa **Services > Intrusion Detection > Alerts** → deberías ver alertas (p. ej. del tipo "*id check returned root*" o de escaneo).

⚠ **Gotcha de laboratorio (VirtualBox):** Suricata usa *netmap*. Si la tarjeta virtual no lo soporta del todo, fuerza el modo emulado: **System > Settings > Tunables** → crea/edita **dev.netmap.admode** con valor **2** y reinicia. En **modo IDS** (solo alertas) funciona en casi cualquier NIC virtual; el **modo IPS** (descartar) es más exigente con el hardware.

Para pasar a IPS (bloquear de verdad): pon **Capture mode = Divert (IPS)** , usa **Firewall > Rules [new]** con la opción "**Divert-to**" apuntando el tráfico a inspeccionar, y marca como **drop** las reglas/políticas que quieras. Así el firewall **deja caer** el paquete malicioso, que es justo el "Response" de NDR.

9.3 Bloqueo por país (GeoIP) — opcional

Firewall > Aliases > + → Tipo **GeoIP** (requiere configurar una fuente MaxMind/IPinfo en la pestaña *GeoIP settings*) → selecciona países → úsalo como **Destination** en una regla **Block** en LAN. Útil para hablar de superficie de ataque y de bloqueo por reputación geográfica.

9.4 Proxy web (Squid) — solo como pista

OPNsense incluye **Services > Web Proxy** (Squid), el filtrado a nivel de aplicación de la lectura de proxies. Es potente pero más laborioso (proxy transparente, y la inspección de HTTPS exige certificado propio). Si quieres profundizar, parte de la documentación oficial: <https://docs.opnsense.org/manual/proxy.html>. *Para esta práctica, el Método A (DNS) ya cubre el bloqueo de webs.*

10. Extensión hacia la DMZ (bonus)

Para convertir esto en una DMZ real sin rehacer nada:

1. Añade un **Adaptador 3** a OPNsense → otra **Red interna dmz-blue** .
 2. En consola (**1) Assign interfaces**) asígnalo como **OPT1**; en la web (**Interfaces > [OPT1]**) habilítalo con, p. ej., **192.168.20.1/24** + DHCP.
 3. Mueve **Debian** (como "servidor") a **dmz-blue** .
 4. Reglas: permite **LAN** → **DMZ** lo necesario, pero **bloquea DMZ** → **LAN** (que un servidor comprometido **no** alcance la red interna). Ese es el principio de *acceso restringido* de la lectura de DMZ.
-